

# Cloud Hacking – Amazon S3

# Cloud Hacking – Amazon S3



## ◆ What is Amazon S3?

- Amazon Simple Storage Service (S3) is a **cloud-based object storage service**.
- Allows users to **store and retrieve any amount of data** at any time from anywhere.
- Common use cases:
  - Backups
  - File storage
  - Static website hosting



## ◆ Why Focus on S3 Hacking?

- Misconfigured S3 buckets can expose **sensitive data** to unauthorized users.
- Attackers exploit **weak or improper access controls** to read/write into the buckets.

💡 دي تعتبر أساسيات لازم تكون عارفها عن S3، وبنركز عليها لأنها أكثر مكان بيحصل فيه **misconfiguration**.



## ◆ Bucket & Objects

- **Bucket:**  
Container for objects stored in Amazon S3.

- **Object:**

Files stored inside a bucket (e.g., images, documents, backups).

---

س

## ◆ Permissions

---

- **Public/Private access settings** bucket. تتحكم مين يقرأ/يكتب في الـ
- **Policies & Access Control Lists (ACLs):** تحدد صلاحيات المستخدمين والأدوار

⚠ خلي بالك إن الـ **permissions** هي المكان اللي بيكون فيه اللعب كله.

---

س

## ◆ Common Access Levels

---

- **Public Read:** Anyone can read objects in the bucket.
- **Public Write:** Anyone can write objects to the bucket (**إخطير جدًا**).
- **Private:** Only authenticated users can access the bucket.

👉 لو لقيت bucket فيه **Public Write** = ثغرة خطيرة.

---

س

## ◆ Tools for Cloud Hacking

---

- **AWS CLI** → Official AWS command-line tool (الأهم وهنستخدمه).
- **Boto3** → Python SDK for AWS.
- **S3Scanner / S3BucketList** → لاكتشاف الـ misconfigured buckets.
- **Burp Suite + AWS Extension** → Testing S3 integrations.

---

س

1. لما تاجر سيرفر بيدوك حاجة زي `username` → من خلالها بيتحددك `bucket`.
2. ممكن تاجر سيرفر 1TB RAM أو أكثر.
3. بيربطوا الدومين بتاعك بالسيرفر عن طريق `CNAME`.
4. عشان تجيب الـ `CNAME`:

```
dig subdomain.example.com
```

```
## ♦ Bucket URLs

- http://s3.amazonaws.com/[bucket_name]/

- http://[bucket_name].s3.amazonaws.com/

Subdomain: من الـ Bucket استخراج اسم الـ

```bash
dig CNAME subdomain.example.com
```

- لو معاك list من subdomains:

```
dig -f subs.txt CNAME | grep s3
```

```
Windows PowerShell
; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;help.mds.swisscom.ch.      IN      A
;; ANSWER SECTION:
help.mds.swisscom.ch.      3600    IN      CNAME   mds.extendedhelp.anyware.com.
mds.extendedhelp.anyware.com. 600     IN      CNAME   mds.extendedhelp.anyware.com.s3-website-us-east-1.amazonaws.com.
mds.extendedhelp.anyware.com.s3-website-us-east-1.amazonaws.com. 293     IN      CNAME   s3-website-us-east-1.amazonaws.com.
s3-website-us-east-1.amazonaws.com. 5 IN A     52.217.170.253
s3-website-us-east-1.amazonaws.com. 5 IN A     54.231.203.93
s3-website-us-east-1.amazonaws.com. 5 IN A     52.217.171.237
s3-website-us-east-1.amazonaws.com. 5 IN A     16.182.66.245
s3-website-us-east-1.amazonaws.com. 5 IN A     52.216.187.42
s3-website-us-east-1.amazonaws.com. 5 IN A     52.216.139.170
s3-website-us-east-1.amazonaws.com. 5 IN A     54.231.168.149
s3-website-us-east-1.amazonaws.com. 5 IN A     52.217.9.147
;; Query time: 196 msec
;; SERVER: 67.207.67.3#53(67.207.67.3) (UDP)
;; WHEN: Tue Jul 30 20:35:14 UTC 2024
```

- أي IP يبدأ بـ `52 / 54 / 50` → في الغالب تبع Amazon AWS.
- تشوف الـ ranges كلها من هنا: [AWS IP Ranges](#)

⚠ استغلال: لو مدة إيجار الدومين خلصت → تقدر تاجر مكانه وتستحوذ عليه.

## ◆ Useful Resources

---

- flaws.cloud → موقع تدريبي لاستغلال Misconfigured Buckets.
- AWS CLI Setup

### تنشيط :AWS CLI

---

```
sudo apt install awscli aws configure
```

- (محتاج Access Keys من AWS – غالبًا لازم فيزا عشان التسجيل).



### أوامر للتعامل مع الـ Buckets 🔍

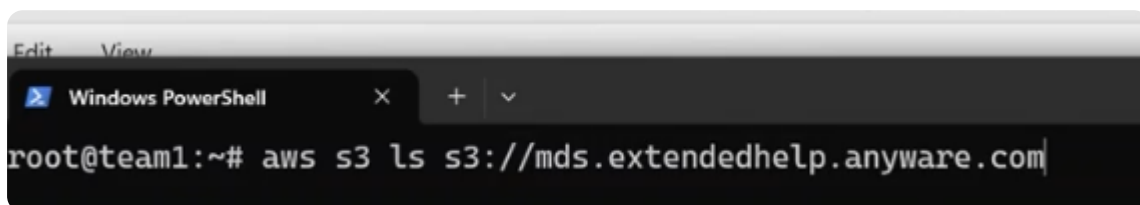
---

- لو عرفت الـ `bucketname` :

```
aws s3 ls s3://bucketname --region <region> --no-sign-request
```

- لو معاك `domain` بدل الاسم:

```
aws s3 ls s3://domainname --region <region> --no-sign-request
```



## ◆ Download from Bucket

---

```
aws s3 cp s3://bucketname/filename ./
```

## ◆ Upload to Bucket

---

```
aws s3 cp ./example.com s3://bucketname
```

⚠ غالبًا محتاج مفاتيح AWS عشان خطوة الـ **upload**.

## ◆ ACLs (Access Control Lists)

---

• تحدد مين يقدر يعمل إيه على البكت:

- **READ** → قراءة.
- **WRITE** → كتابة.
- **READ\_ACP** → قراءة ACL.
- **WRITE\_ACP** → تعديل ACL.
- **FULL\_CONTROL** → كل الصلاحيات.

## ◆ Bucket Policies

---

- بتندي أو تمنع صلاحيات على مستوى JSON-based policies
  - **Bucket**
  - **Object**

## ◆ Common Misconfigurations

---

- **Allowing s3:ListBucket to Everyone** → للملفات list أي حد يقدر يعمل.
- **Allowing s3:GetObject to Everyone** → أي حد يقدر يحمل الملفات.
- **Allowing s3:PutObject to Everyone** → أي حد يقدر يرفع ملفات.

```
aws s3api get-bucket-acl --bucket <bucket-name>
```

```
{
  "Owner": {
    "DisplayName": "owner",
    "ID": "abc12345"
  },
  "Grants": [
    {
      "Grantee": {
        "Type": "Group",
        "URI": "http://acs.amazonaws.com/groups/global/AllUsers"
      },
      "Permission": "READ"
    }
  ]
}
```

- حتى لو رفض يملك **ls** → جرب ACL command.
- ممكن تلاقي صلاحياتك أعلى من المتوقع وتعديلها.
- خطوات:
  1. تحمل الملف (cp).
  2. تعدل الصلاحيات.
  3. ترفعه تاني.

```
},
"Grants": [
  {
    "Grantee": {
      "Type": "Group",
      "URI": "http://acs.amazonaws.com/groups/global/AllUsers"
    },
    "Permission": "READ_ACP"
  }
]
```

⚠ الحالة دي تعتبر **CRITICAL Vulnerability**:

- FULL\_CONTROL = كل الصلاحيات.
- تقدر تقرأ / تكتب / تعدل ACL / ترفع أو تمسح بيانات.

س

## ◆ مواقع مساعدة

- GrayHatWarfare Buckets
  - فيه كل أسماء الـ Buckets المكشوفة عالمياً.
  - تقدر تعمل فلترة وتدور على الموقع المستهدف.
  - لو قدرت تعمل **ls** → يبقى فيه ثغرة.